SOC L1 LAB · INC-002

INC-002: Rogue Local Account Findings Report

Identity creation, privilege assignment, and the rule that named it

INCIDENT	INC-002, Rogue local account added to sudo
REPORT DATE	2026-11-01
CLASSIFICATION	Lab exercise, sanitized for publication
ENVIRONMENT	Wazuh 4.14.7 · Debian 12 · QEMU/KVM
SEVERITY	High

Independent portfolio lab. No production systems, client data, or real credentials.

Contents

1. Executive summary
2. Scope and methodology
3. Environment
4. Narrative
5. Timeline
6. Evidence
7. Detection analysis
8. Root cause
9. Impact
10. Severity
11. Response actions
12. Recommendations
13. Lessons learned

Appendix A: Custom rule
Appendix B: MITRE ATT&CK
Appendix C: Evidence index
Appendix D: Glossary

Incident	INC-002, Rogue local account added to the `sudo` group
Classification	Lab exercise, sanitized for publication
Activity date	2026-10-31
Report date	2026-10-31
Author	SOC L1 portfolio lab
Status	Closed, escalated
Severity	High
Related	`tickets/INC-002-rogue-account.md`, `writeups/INC-002-rogue-account.md`, `docs/evidence/INC-002-*`

---

1. Executive summary

At 04:30:46 UTC, the administrator account `analyst` created a local account named `svc-ops` on the Debian endpoint `soc-victim`. The account received an interactive shell, a home directory, and a password. One second later it was added to the `sudo` group, which on this host is equivalent to root capability.

There was no change request, no maintenance window, and no business reason for a service account to have either a shell or `sudo`.

Wazuh detected the sequence in three layers:

Time (UTC)	Rule	Meaning
04:30:46	FIM 550	`/etc/passwd`, `/etc/group`, `/etc/shadow`, `/etc/gshadow` modified
04:30:48	100121 (custom, level 12)	`Privilege assignment: user added to the sudo group (svc-ops)`
04:30:48	5902 / 5901 (level 8)	New user and new group

The important difference is between the last two rows. Stock rules reported that an account appeared. The custom rule reported that it was given root capability, and named the account in the alert title. In a window that produced 237 alerts, that distinction is the difference between a deferred identity event and a same-shift escalation.

The account was removed from `sudo` and deleted at 04:32:07. No privileged command was executed by the account before containment.

---

2. Scope and methodology

2.1 Scope

In scope	Out of scope
One Debian 12 VM (`soc-victim` , 10.0.2.15)	Production systems
Wazuh manager, indexer, dashboard	Any external network
auditd, FIM on `/etc` , journald	Real credentials or personal data
Actor: `analyst` (uid 1000) via `sudo`	Employer or client environments

2.2 Method

1. Confirm the base lab is healthy: agent active, auditd keys loaded, FIM realtime on `/etc` .
2. Deploy and validate the custom privilege-assignment rule.
3. Generate routine administrator activity so the change is not the only event in the queue.
4. Create the account, set a password, and add it to `sudo` from an authenticated admin session.
5. Let the SIEM collect without intervention, then reconstruct the event from alerts, journal, audit, and FIM.
6. Contain, preserve evidence, and write the ticket.

2.3 Limitations

- **Actor**
  The creator is the lab administrator. This models two real cases that look identical in logs: a compromised admin session and an insider creating a backdoor account. Only change-control evidence can separate them.
- **Source address**
  All sessions arrive from the QEMU gateway `10.0.2.2` , so source IP does not distinguish the actor from routine admin activity.
- **Scale**
  One host. No directory service, no IAM approval workflow.
- **Synthetic data**
  The account, UID, and password were created for the exercise.

---

3. Environment

Component	Detail
SIEM	Wazuh 4.14.7, single-node Docker
Endpoint	Debian 12, 1.5 GB VM
Agent	Wazuh agent 4.14.7, ID 001, `soc-victim`
Process telemetry	auditd execve, key `audit-wazuh-c`
File watches	auditd write watches, key `audit-wazuh-w`
FIM	realtime on `/etc`, `/home`, `/var/www/html`
Actor	`analyst` (uid 1000), `sudo` to root
Source	10.0.2.2 (QEMU gateway)
Clock	UTC

Relevant audit watches:

```
-w /etc/passwd -p wa -k audit-wazuh-w
-w /etc/group -p wa -k audit-wazuh-w
-w /etc/sudoers -p wa -k audit-wazuh-w
-w /etc/cron.d -p wa -k audit-wazuh-w
-w /var/www/html -p wa -k audit-wazuh-w
-a always,exit -F arch=b64 -S execve -k audit-wazuh-c
```

---

4. Narrative

4.1 Account creation

At 04:30:46, the administrator opened a root context through `sudo` and ran:

```
sudo useradd -m -s /bin/bash svc-ops
echo 'svc-ops:Summer2026!' | sudo chpasswd
sudo usermod -aG sudo svc-ops
id svc-ops
```

Result:

```
uid=1003(svc-ops) gid=1003(svc-ops) groups=1003(svc-ops),27(sudo)
```

The naming convention (`svc-`) suggests a service account. The attributes say otherwise:

Attribute	Value	Why it matters
UID / GID	1003 / 1003	New local identity
Shell	`/bin/bash`	Interactive login is possible
Home	`/home/svc-ops`	Normal user home
Password	Set via `chpasswd`	Password authentication is possible
Group	`sudo` (gid 27)	Root capability via `sudo`

4.2 Group membership

`getent group sudo` after the change:

```
sudo:x:27:analyst,debian,svc-ops
```

`analyst` and `debian` are the expected members. `svc-ops` is not. The group line is the single most important piece of evidence: it is the privilege assignment, not the account creation.

4.3 Use of the account

No `sudo` command was executed by `svc-ops` in the window, and no SSH login as the account is present. The risk is prospective: the account had a known password and root capability, so the next step for an attacker would have been trivial.

4.4 Containment

At 04:32:07:

```
sudo gpasswd -d svc-ops sudo
sudo userdel -r svc-ops
```

Verified afterwards:

```
sudo:x:27:analyst,debian
svc-ops removed
home removed
```

---

5. Timeline

Time (UTC)	Source	Event
04:30:46	audit / journal	`sudo useradd -m -s /bin/bash svc-ops`
04:30:46	audit	`chpasswd` sets the account password
04:30:46.935	FIM 550	`/etc/passwd` modified
04:30:46.971	FIM 550	`/etc/group` modified
04:30:46.987	FIM 550	`/etc/gshadow` modified
04:30:47.003	FIM 550	`/etc/shadow` modified
04:30:47	audit / journal	`sudo usermod -aG sudo svc-ops`
04:30:47	audit	`id svc-ops` to groups include `sudo`
04:30:48.390	Wazuh 100121	Privilege assignment, `svc-ops`
04:30:48.942	Wazuh 5901	New group added
04:30:48.947	Wazuh 5902	New user added, uid 1003
04:32:07	admin action	Removed from `sudo` , account deleted

The audit alerts appear about 1.5 seconds after the journal because Wazuh groups the multi-record audit event before decoding it. The journal is the authoritative time source for the actions.

---

6. Evidence

6.1 Alert volume

Window: 04:30:40–04:32:00 UTC, agent `soc-victim` .

Rule	Description	Count
80792	Audit: command executed	160
550	FIM: integrity checksum changed	16
5501	PAM: login session opened	13
554	FIM: file added	10
5502	PAM: login session closed	10
553	FIM: file deleted	7
5402	Successful sudo to root	5
5715	sshd authentication success	5
5902	New user added	1
5901	New group added	1
100121	Privilege assignment	1
	Total	237

6.2 File integrity

File	Event	SHA-256 (after)	Size
`/etc/passwd`	modified	`5eb13b8f3e6b700c27889498f86a2357849c3c4a89debc9e197faf9c8e5b34f6`	1534
`/etc/group`	modified	`d49d784922f962f1c8f1ed66224fca729ffa3fdbe6f706b0ee74119367bc9243`	798
`/etc/shadow`	modified	`b43e646c7887f19cc082368203f7b677270288b73058bef5b52e56e0d750b550`	959
`/etc/gshadow`	modified	`54db336ca4c1e7326b86370f1a4e6e70521fdc191b3be6c278aa52d4d9ba31a2`	675

6.3 Audit record for the privilege assignment


```
{
  "rule": { "id": "100121", "level": 12,
            "description": "Privilege assignment: user added to the sudo group (svc-ops)" },
  "data": {
    "audit": {
      "exe": "/usr/sbin/usermod",
      "execve": { "a0": "usermod", "a1": "-aG", "a2": "sudo", "a3": "svc-ops" },
      "auid": "1000",
      "uid": "0",
      "key": "audit-wazuh-c"
    }
  }
}
```

6.4 Decoded command trail

```
04:30:46Z  sudo useradd -m -s /bin/bash svc-ops
04:30:46Z  useradd -m -s /bin/bash svc-ops
04:30:46Z  sudo chpasswd
04:30:46Z  chpasswd
04:30:47Z  sudo usermod -aG sudo svc-ops
04:30:47Z  usermod -aG sudo svc-ops
04:30:47Z  id svc-ops
```

Full evidence: `docs/evidence/INC-002-{alerts.json,account.log,account-commands.txt,membership.txt}`.

---

7. Detection analysis

7.1 What fired, and how fast

Rule	Trigger	Latency	Value
550	FIM checksum change	~1 s	Proves the identity files changed
100121	`usermod` with `a2=sudo`	~1.4 s	Names the privilege assignment and the account
5902	New user	~2 s	Identity event, level 8
5901	New group	~2 s	Supporting context

7.2 Why 5902 is not enough

Stock 5902 emits:

```
{
  "rule": { "id": "5902", "level": 8, "description": "New user added to the system." },
  "data": { "dstuser": "svc-ops", "uid": "1003", "gid": "1003",
            "home": "/home/svc-ops", "shell": "/bin/bash," }
}
```

It tells the analyst that a user exists. It does not say the user was placed in a privileged group. At level 8, in a window of 237 alerts, it is the kind of event that waits behind 160 audit commands.

7.3 Why 100121 is precise

```
<rule id="100121" level="12">
  <if_sid>80792</if_sid>
  <field name="audit.exe">/usr/sbin/usermod</field>
  <field name="audit.execve.a2" type="pcre2">^(sudo|wheel|admin)$</field>
  <description>Privilege assignment: user $(audit.execve.a3) added to privileged group
$(audit.execve.a2) via usermod</description>
  <mitre>
```

```
    <id>T1098</id>
    <id>T1548.003</id>
  </mitre>
  <group>audit_command,privilege_escalation,</group>
</rule>
```

- It keys on the binary (`usermod`), not on a file diff.
- It keys on the group argument (`a2` , matched with anchored PCRE2), which covers both `-aG` (append) and `-G` (replace).
- It puts the affected account (`a3`) in the description.

The repository also carries rules 100123–100126 for the other common paths: `gpasswd -a` , Debian `adduser` , `useradd -G` , and the `usermod -a -G` argument shape. The full family, its test matrix, and its gaps are in `rules/inc-002-rules.md` .

7.4 False-positive validation

The rule family was re-run against legitimate group administration, including group names that contain a privileged name as a substring. The first version used an unanchored alternation (`sudo|wheel|admin`) and produced false positives on `sudo-audit` , `admin-tools` , and `wheelhouse` .

The fix was an anchored PCRE2 field:

```
<field name="audit.execve.a2" type="pcre2">^(sudo|wheel|admin)$</field>
```

After the change, the legitimate groups were silent and an exact `sudo` assignment still fired. The full test matrix is in `rules/inc-002-rules.md` §5.1.

7.5 What did not fire

Gap	Consequence
No stock rule for "account added to a privileged group"	The escalation is invisible to level-8 triage
No change-window correlation	The rule cannot know whether the change was approved
No rule for `useradd` outside a window	A new account is only a level-8 event
No rule for a service account with a shell	`svc-ops` looks like a normal user
No protection against direct `/etc/group` edits	`100121` only matches `usermod`

---

8. Root cause

8.1 Direct cause

An authenticated administrator created an account and granted it `sudo` without a change request or business justification.

8.2 Contributing factors

Factor	Effect
No approval workflow for identity changes	Nothing blocked or challenged the action
`svc-` naming used for an interactive account	The name implied a service account, but the attributes were a normal user
Interactive shell and password	The account could log in and authenticate
Membership in `sudo`	Root capability
Level-8 detection	The event was easy to defer
No group baseline	No alert on unexpected `sudo` membership

8.3 Five whys

1. Why was there a rogue sudo account? An admin created it and added it to `sudo`.
2. Why was that possible? Local account and group management had no approval gate.
3. Why did it look legitimate? The `svc-` name and a routine admin session.
4. Why was it not caught immediately? Stock detection reported a new user at level 8, not a privilege assignment.
5. Why was the privilege not modelled? The detection set treated identity objects (users, groups) as inventory events, not as privilege changes.

---

9. Impact

Dimension	Assessment
Confidentiality	Root-capable account existed with a known password. No data access observed
Integrity	Local identity database modified. `sudo` group membership changed
Availability	None
Blast radius	One host in the lab. In production, the account's reachable systems
Persistence	Account and password would survive a reboot. Removed during containment

The risk is not the account creation itself. It is that a known password plus `sudo` membership gives an attacker a durable path to root, and the account looks plausible enough to survive a casual review.

---

10. Severity

High

- **Not Critical**
  No privileged command was executed by the account, no persistence was installed, and the actor was an authenticated administrator.

- **Not Medium**
  `sudo` membership is root capability, the password was known, and the account had an interactive shell. A casual review that missed the group line would have left a backdoor.

If the actor's session were later shown to be compromised, the rating would move to Critical.

---

11. Response actions

1. Removed `svc-ops` from the `sudo` group at 04:32:07.
2. Deleted the account and home directory.
3. Verified the group returned to `analyst,debian`.
4. Preserved alerts, journal, audit records, and the membership snapshot.
5. Escalated for a change-control and insider-risk review.

---

12. Recommendations

Immediate

#	Action
1	Confirm whether `analyst` was authorised. If not, treat the session as compromised
2	Search other hosts for `svc-ops` and for the same creation pattern
3	Review `sudo` group membership and `sudoers` files across the estate
4	Check the account for SSH keys, cron, systemd units, and shell profiles before deletion
5	Preserve the evidence set before further changes

Short term

#	Action
6	Deploy 100121–100126. Extend the group alternation (`sudo|wheel|admin`) to your estate or a CDB list
7	Baseline `sudo` group membership and alert on drift
8	Require `nologin` and no `sudo` for service accounts
9	Integrate identity changes with change control. Include the ticket ID in the audit trail
10	Raise new-account alerts outside approved windows

Long term

#	Action
11	Centralise account lifecycle in an approved IAM workflow
12	Run periodic privileged-group attestation
13	Add detection-as-code tests for 5901/5902/100121
14	Alert on direct edits to `/etc/group` and `/etc/sudoers`
15	Tabletop the "admin creates a backdoor account" scenario

---

13. Lessons learned

- **A new user is not the finding. The privilege assignment is**
- **Detection should name the capability, not just the object**
  "New user" and "new sudo user" are different risks.
- **Naming is not a control**
  `svc-ops` looked like a service account and was still an interactive, password-authenticated, root-capable user.
- **FIM and audit answer different questions**
  FIM says `/etc/group` changed. Audit says who changed it and to which group.
- **The response order matters**
  Remove the privilege before deleting the account, and check for persistence before deleting the home directory.

Appendix A: Custom rule

```
<rule id="100121" level="12">
  <if_sid>80792</if_sid>
  <field name="audit.exe">/usr/sbin/usermod</field>
  <field name="audit.execve.a2" type="pcre2">^(sudo|wheel|admin)$</field>
  <description>Privilege assignment: user $(audit.execve.a3) added to privileged group
$(audit.execve.a2) via usermod</description>
  <mitre>
    <id>T1098</id>
    <id>T1548.003</id>
  </mitre>
  <group>audit_command,privilege_escalation,</group>
</rule>
```

Test:

```
sudo useradd -m -s /bin/bash svc-test
sudo usermod -aG sudo svc-test
# expect 100121 within ~1 s, naming svc-test
sudo gpasswd -d svc-test sudo && sudo userdel -r svc-test
```

Appendix B: MITRE ATT&CK

Technique	ID	Evidence
Create local account	T1136.001	`useradd -m -s /bin/bash svc-ops`
Account manipulation	T1098	`usermod -aG sudo svc-ops`
Abuse elevation control: sudo	T1548.003	Membership in group `sudo`
Valid accounts	T1078	Actor `analyst` using sudo

Appendix C: Evidence index

File	Contents
`docs/evidence/INC-002-alerts.json`	237 alerts from the incident window
`docs/evidence/INC-002-account.log`	Journal excerpt with sudo and audit lines
`docs/evidence/INC-002-account-commands.txt`	Decoded command trail
`docs/evidence/INC-002-membership.txt`	`sudo` group and account record before cleanup

Appendix D: Glossary

Term	Meaning
FIM	File integrity monitoring
`sudo` group	Debian's default group whose members may run commands as root
`auid`	Audit loginuid: the account that started the session
`euid`	Effective UID at execution time
CDB list	Wazuh's constant database lookup, used for key/value matching